

API SECURITY RISK ANALYSIS

Security assessment of the API tested:
`jsonplaceholder.typicode.com`

SEPTEMBER 2026

Prepared by
Yuvraj Singh



JSONPLACEHOLDER.TYPICODE.COM SECURITY ASSESSMENT

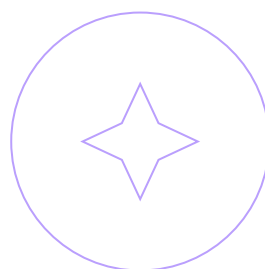
6 Findings Identified

Total Findings and Severity Levels

Key Findings



Ranging from
High to Low
severity



Authentication
and authorization
weaknesses exist

Methodology

API Testing Process Overview

Testing was performed manually using Postman against `jsonplaceholder.typicode.com`. This involved a structured approach to identify vulnerabilities in the API. Key activities included reconnaissance of endpoints, assessing authentication requirements, and checking for permission validations on user-specific data. Each endpoint was selectively tested to ensure thorough coverage of potential weaknesses. This hands-on method allowed for direct observation of how the API behaves under various inputs and conditions, aiming to uncover security flaws that could be exploited by malicious actors.

The methodology also included testing boundary conditions by inputting invalid or out-of-range IDs to assess the API's error handling and response behavior. Detailed inspection of HTTP response headers provided insight into existing security controls, while payload testing on POST endpoints evaluated input validation robustness. The use of Postman's Authorization tab confirmed whether authentication configurations were properly set. This comprehensive approach ensured that each aspect of the API's security posture was evaluated, leading to the identification of several critical vulnerabilities.



Findings & Impact

This section presents the findings from the security audit of `jsonplaceholder.typicode.com`, highlighting risk severity, technical descriptions, and potential business impacts of each vulnerability.

Findings, Severity & Business Impact

1. No Authentication on GET /users — SEVERITY: HIGH

Full user PII (name, email, phone, address, geo-coordinates) is accessible to anyone with no authentication required.

Business impact: Mass exposure of customer PII could trigger data-breach notification obligations, regulatory fines, and loss of user trust.

2. Broken Object Level Authorization (BOLA/IDOR) on GET /users/{id} — SEVERITY: MEDIUM-HIGH

Any user's full record is retrievable by changing the ID in the URL, with no ownership or permission check.

Business impact: Attackers can systematically harvest every user record, enabling large-scale identity theft or targeted phishing.

3. No Authentication on POST /posts (write access) — SEVERITY: HIGH (context-dependent)

Write operations are accepted with no authentication.

Business impact: Anyone can create, spam, or corrupt data on a production system, damaging data integrity and service reliability.

4. Verbose Error Disclosure (500 error exposes Node.js stack trace) — SEVERITY: MEDIUM-HIGH

Malformed input triggered a server error that leaked internal file paths and stack trace details.

Business impact: Leaked internal details give attackers a roadmap for further, more targeted attacks against backend infrastructure.

5. Insufficient Input Validation — SEVERITY: MEDIUM

API accepted empty bodies, wrong data types, oversized strings, and script-tag content without rejecting or sanitizing them.

Business impact: Increases risk of downstream injection attacks, data corruption, and stored XSS if content is later rendered elsewhere.

6. Missing Security Headers (X-Frame-Options, Content-Security-Policy) — SEVERITY: LOW

Response headers lacked clickjacking and content-injection protections.

Business impact: Increases exposure to clickjacking and content-injection attacks against any front-end that consumes this API.

Remediation Recommendations

Addressing API Security Findings

The remediation recommendations address the key findings identified during the security assessment of the API at

`jsonplaceholder.typicode.com`. Each recommendation is tailored to mitigate specific risks, ensuring that security measures are effectively implemented.

Prioritizing authentication, authorization, and input validation measures is critical for protecting sensitive data and maintaining user trust. By following these recommendations, the API can enhance its security posture and reduce vulnerabilities, aligning with best practices for API security as outlined by OWASP.

Implementing the suggested remediation steps will help organizations safeguard their APIs against potential attacks. Establishing proper authentication mechanisms, such as OAuth2 or JWT, will ensure that only authorized users have access to sensitive endpoints. Additionally, server-side checks for object-level authorization will prevent unauthorized data access. It is also crucial to enforce input validation and implement security headers to protect against injection attacks and content security issues, thereby fortifying overall API integrity and user safety.

Remediation Recommendations (matched to each finding)

1. No Auth on GET /users → Implement authentication (OAuth2 / API key / JWT) on all endpoints and return only authorized fields.
2. BOLA/IDOR → Add server-side object-level authorization checks (OWASP API1:2023) verifying the caller has permission for the specific requested ID.
3. No Auth on POST /posts → Require authentication and role-based access control before allowing create/update/delete.
4. Verbose Error Disclosure → Add centralized error-handling middleware that returns generic sanitized messages to clients; log full details only server-side; disable stack traces in production.
5. Insufficient Input Validation → Enforce strict server-side schema validation; reject wrong types, oversized payloads, and script content with proper 400 responses.
6. Missing Security Headers → Add Helmet.js or equivalent middleware to set X-Frame-Options, Content-Security-Policy, Strict-Transport-Security, and Referrer-Policy headers.

Priority order: fix authentication and authorization first (highest business impact), then error handling and input validation, then security headers.

PRIORITIZING KEY REMEDIATION AREAS

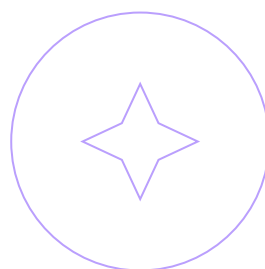
6 findings identified

Findings Severity Overview

Focus on Auth



Immediate
remediation is
critical



Authentication
fixes have the
highest impact